

Выполнил: Якубенко Вадим, группа Р4110

Девайс: компьютер с эмулятором

Эмулятор: BlueStacks 5

Настроенный прокси Proxuman:

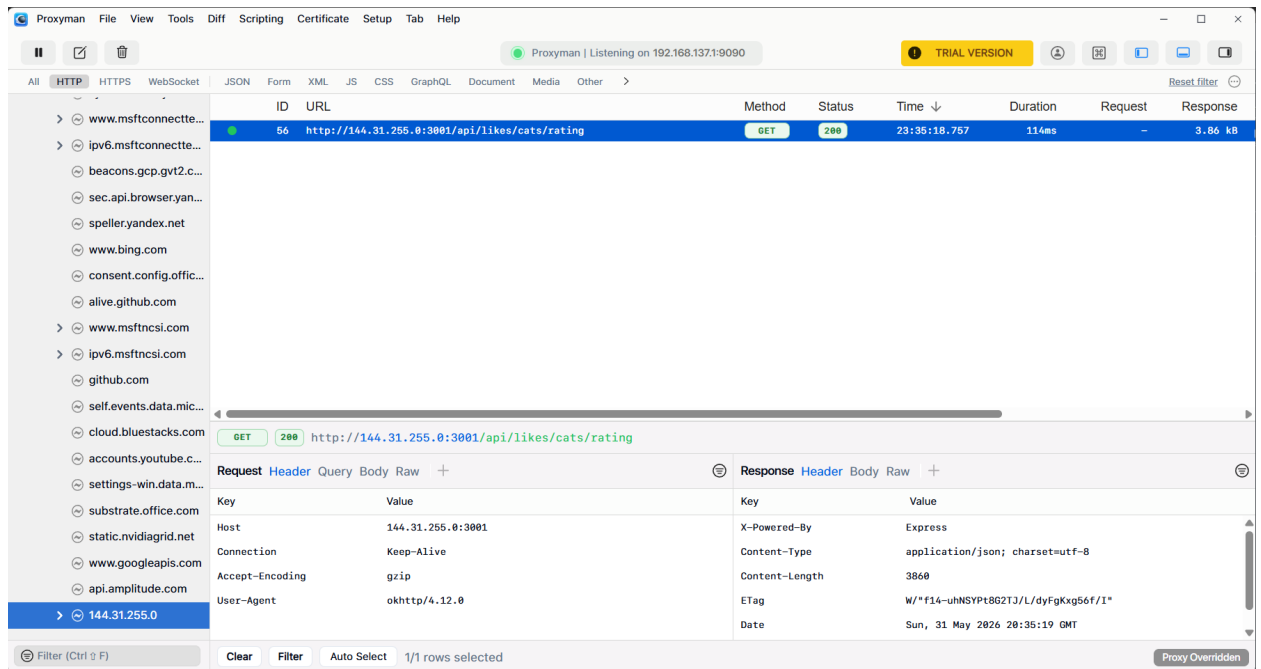


Рисунок 1 – настроенный Proxuman

## Часть 1. Разведка API через Swagger

Открыть Swagger по адресу <http://144.31.255.0:3001/api-docs-ui/>:

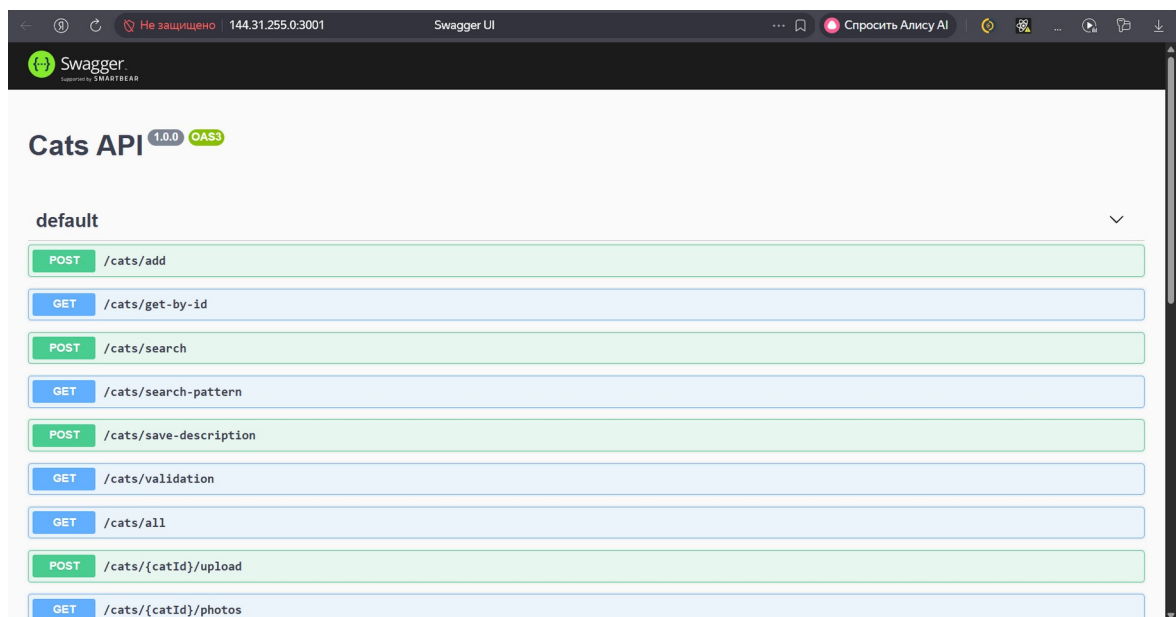


Рисунок 2 – открытый Swagger

- поиска котиков;
- просмотра карточки по `id`;
- добавления имени;
- изменения описания;
- лайка и дизлайка;
- рейтинга;
- просмотра и загрузки фото;
- удаления или изменения данных через web API.

| Method | Path                                         | Назначение                            | Параметры           | Пример запроса                                             | Пример ответа                                                                                                                                                                                                                                        |
|--------|----------------------------------------------|---------------------------------------|---------------------|------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| POST   | http://144.31.255.0:3001/cats/search         | Поиск по имени и доп. характеристикам | Фильтр поиска имени | {<br>"name":<br>"string",<br>"gender":<br>"male"<br>}      | {<br>"groups": [<br>{<br>"title": "string",<br>"count": 0,<br>"cats": [<br>{<br>"id": 0,<br>"name": "string",<br>"description":<br>"string",<br>"tags":<br>["string"],<br>"gender": "male",<br>"likes": 0,<br>"dislikes": 0<br>}<br>]<br>}<br>]<br>} |
| GET    | http://144.31.255.0:3001/cats/get-by-id/{id} | Получение кота по id                  | Id                  | Тело запроса отсутствует<br>значение передаётся в адресной | {<br>"cat": {<br>"id": 0,<br>"name": "string",<br>"description":<br>"string",<br>"tags": [<br>"string"<br>]<br>}<br>}                                                                                                                                |

|      |                                                       |                              |                                                                                   |                                                                                                                   |                                                                                                                                                                                               |
|------|-------------------------------------------------------|------------------------------|-----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      |                                                       |                              |                                                                                   | строке                                                                                                            | ],<br>"gender": "male",<br>"likes": 0,<br>"dislikes": 0<br>}<br>}                                                                                                                             |
| POST | http://<br>144.31.255.0:3001/cats/<br>add             | Добавление<br>списка имен    | Список с<br>именами и<br>полом                                                    | {<br>"cats": [<br>{<br>"name":<br>"string",<br>"gender":<br>"male",<br>"descript<br>ion": "string"<br>}<br>]<br>} | {<br>"cats": [<br>{<br>"id": 0,<br>"name":<br>"string",<br>"description":<br>"string",<br>"tags": [<br>"string"<br>],<br>"gender":<br>"male",<br>"likes": 0,<br>"dislikes": 0<br>}<br>]}<br>} |
| POST | http://<br>144.31.255.0:3001/cats/<br>add             | Сохранение<br>описания имени | Идентификато<br>р кота (catId) и<br>его новое<br>описание<br>(catDescription<br>) | {<br>"catId": 0,<br>"catDescription<br>": "string"<br>}<br>}                                                      | {<br>"id": 0,<br>"name": "string",<br>"description":<br>"string",<br>"tags": [<br>"string"<br>],<br>"gender": "male",<br>"likes": 0,<br>"dislikes": 0<br>}<br>}                               |
| POST | http://<br>144.31.255.0:3001/cats/<br>{catId}/like    | Добавление лайка<br>коту     | Id кота                                                                           | Тело запроса<br>отсутствует<br>значение<br>передаётся в<br>адресной<br>строке                                     | ОК                                                                                                                                                                                            |
| POST | http://<br>144.31.255.0:3001/cats/<br>{catId}/dislike | Добавление<br>дизлайка коту  | Id кота                                                                           | Тело запроса<br>отсутствует<br>значение<br>передаётся в                                                           | ОК                                                                                                                                                                                            |

|     |                                            |                                |     | адресной строке       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-----|--------------------------------------------|--------------------------------|-----|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GET | http://144.31.255.0:3001/cats/likes-rating | Получение списка ТОП-10 лайков | Нет | Параметры отсутствуют | [<br>{<br>"name":<br>"Турбопетров",<br>"likes": 42<br>},<br>{<br>"name":<br>"Леопольд",<br>"likes": 25<br>},<br>{<br>"name":<br>"Обормотик",<br>"likes": 19<br>},<br>{<br>"name":<br>"Вадосик",<br>"likes": 11<br>},<br>{<br>"name":<br>"Новыйбогдан",<br>"likes": 8<br>},<br>{<br>"name": "Буся",<br>"likes": 4<br>},<br>{<br>"name":<br>"Лабакот",<br>"likes": 4<br>},<br>{<br>"name": "Бодя",<br>"likes": 2<br>},<br>{<br>"name": "Велик",<br>"likes": 0<br>},<br>{<br>"name":<br>"Великий",<br>"likes": 0<br>}<br>] |

|      |                                                       |                                      |                |                          |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|------|-------------------------------------------------------|--------------------------------------|----------------|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      |                                                       |                                      |                |                          | ]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| GET  | http://<br>144.31.255.0:3001/cats/<br>dislikes-rating | Получение списка<br>ТОП-10 дизлайков | Нет            | Параметры<br>отсутствуют | [<br>{<br>"name":<br>"Турбопетров",<br>"dislikes": 40<br>},<br>{<br>"name":<br>"Обормотик",<br>"dislikes": 14<br>},<br>{<br>"name":<br>"Вадосик",<br>"dislikes": 11<br>},<br>{<br>"name":<br>"Новыйбогдан",<br>"dislikes": 6<br>},<br>{<br>"name": "Буся",<br>"dislikes": 4<br>},<br>{<br>"name": "Бодя",<br>"dislikes": 0<br>},<br>{<br>"name": "Велик",<br>"dislikes": 0<br>},<br>{<br>"name":<br>"Великий",<br>"dislikes": 0<br>},<br>{<br>"name": "Длинное<br>Описание",<br>"dislikes": 0<br>},<br>{<br>"name": "Имя",<br>"dislikes": 0<br>}<br>] |
| POST | http://                                               | Добавление                           | Id кота и файл | {<br>file:               | {                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

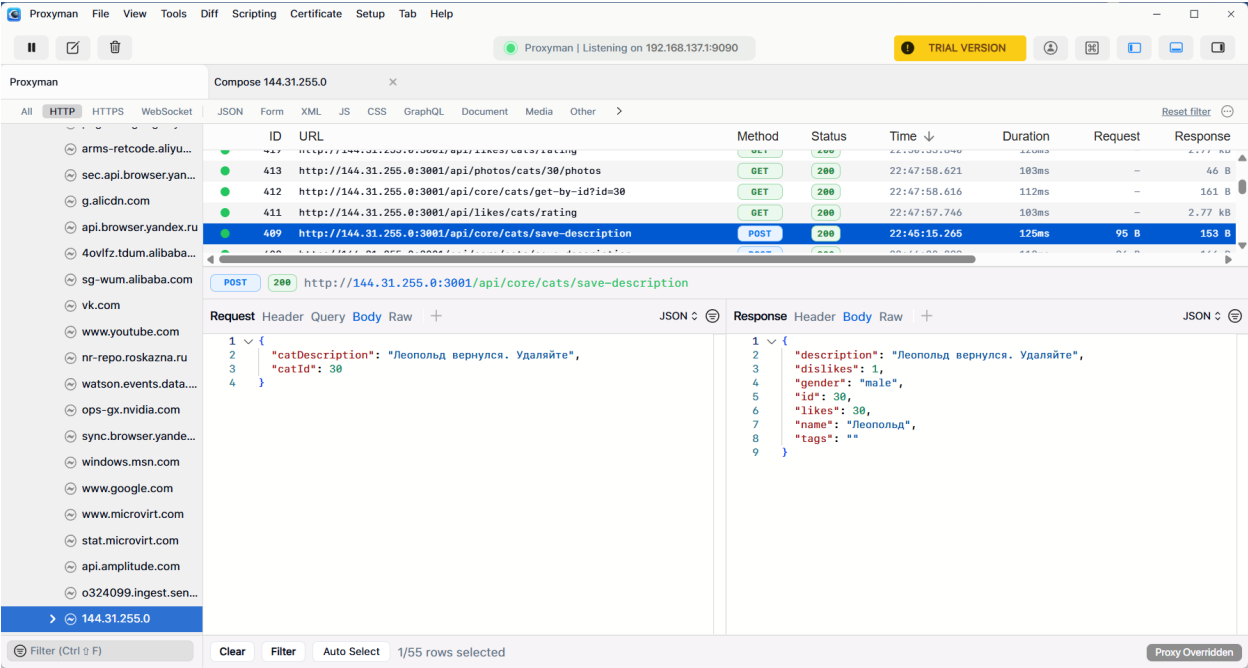
|        |                                                  |                                        |             |                                                                               |                                        |
|--------|--------------------------------------------------|----------------------------------------|-------------|-------------------------------------------------------------------------------|----------------------------------------|
|        | 144.31.255.0:3001/cats/{catId}/upload            | изображения кота                       | изображения | string(\$binary)<br>}                                                         | "fileUrl": "string"<br>}               |
| GET    | http://<br>144.31.255.0:3001/cats/{catId}/photos | Получение<br>изображений по id<br>кота | Id кота     | Тело запроса<br>отсутствует<br>значение<br>передаётся в<br>адресной<br>строке | {<br>"images": [<br>"string"<br>]<br>} |
| DELETE | http://<br>144.31.255.0:3001/cats/{catId}/remove | Удаления кота                          | Id кота     | Тело запроса<br>отсутствует<br>значение<br>передаётся в<br>адресной<br>строке | ОК                                     |

## Часть 2. Карта действий приложения

Включите прокси и выполните в мобильном приложении минимум следующие действия:

- 1. Поиск котика.
- 2. Открытие карточки.
- 3. Лайк.
- 4. Дизлайк.
- 5. Добавление нового котика.
- 6. Изменение описания.
- 7. Загрузка изображения.
- 8. Открытие рейтинга.

Просмотр запроса и ответа в Proxuman:



| Действие в приложении | HTTP method | URL                                           | Request body                                                   | Response code | Response body                                                                                                                                     |
|-----------------------|-------------|-----------------------------------------------|----------------------------------------------------------------|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| Поиск котика          | POST        | http://144.31.255.0:3001/api/core/cats/search | {<br>"gender": null,<br>"name": "Леон",<br>"order": "asc"<br>} | 200           | {<br>"groups": [<br>{<br>"title": "Л",<br>"cats": [<br>{<br>"id": 30,<br>"name": "Леопольд",<br>"description": "Леопольд"        }<br>]<br>}<br>] |

|                          |      |                                                                     |                                                                                                                                    |     |                                                                                                                                                                                                          |
|--------------------------|------|---------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|-----|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                          |      |                                                                     |                                                                                                                                    |     | <pre>вернулся. Больше не удаляйте",   "tags": "",   "gender": "male",   "likes": 25,   "dislikes": 0 } ], "count": 1 } ]</pre>                                                                           |
| Открытие карточки        | GET  | <code>http://144.31.255.0:3001/api/core/cats/get-by-id?id=30</code> | Empty Body                                                                                                                         | 200 | <pre>{   "cat": {     "id": 30,     "name": "Леопольд",     "description": "Леопольд вернулся. Больше не удаляйте",     "tags": "",     "gender": "male",     "likes": 25,     "dislikes": 0   } }</pre> |
| Лайк                     | POST | <code>http://144.31.255.0:3001/api/likes/cats/30/likes</code>       | <pre>{   "dislike": false,   "like": true }</pre>                                                                                  | 200 | <pre>{   "id": 30,   "name": "Леопольд",   "description": "Леопольд вернулся. Больше не удаляйте",   "tags": "",   "gender": "male",   "likes": 26,   "dislikes": 0 }</pre>                              |
| Дизлайк                  | POST | <code>http://144.31.255.0:3001/api/likes/cats/30/likes</code>       | <pre>{   "dislike": true,   "like": false }</pre>                                                                                  | 200 | <pre>{   "id": 30,   "name": "Леопольд",   "description": "Леопольд вернулся. Больше не удаляйте",   "tags": "",   "gender": "male",   "likes": 26,   "dislikes": 1 }</pre>                              |
| Добавление нового котика | POST | <code>http://144.31.255.0:3001/api/core/cats/add</code>             | <pre>{   "cats": [     {       "description": "Самый лучший кот",       "gender": "male",       "name": "Братик"     }   ] }</pre> | 200 | <pre>{   "cats": [     {       "id": 51,       "name": "Братик",       "description": "Самый лучший кот",       "tags": ""     }   ] }</pre>                                                             |



|                      |      |                                                         |                                                                                 |     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|----------------------|------|---------------------------------------------------------|---------------------------------------------------------------------------------|-----|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                      |      |                                                         | <pre>} ]</pre>                                                                  |     | <pre>"gender": "male", "likes": 0, "dislikes": 0 } ]</pre>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Изменение описания   | POST | http://144.31.255.0:3001/api/core/cats/save-description | <pre>{   "catDescription": "Лучше этого кота нет никого",   "catId": 51 }</pre> | 200 | <pre>{   "id": 51,   "name": "Братик",   "description": "Лучше этого кота нет никого",   "tags": "",   "gender": "male",   "likes": 0,   "dislikes": 0 }</pre>                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Загрузка изображения | GET  | http://144.31.255.0:3001/photos/image-1780261263911.jpg | Empty Body                                                                      | 200 | <div>Response Header Body Raw + JPEG</div>  <div>Show Inspector 640 x 640 pixels • 129 kB</div>                                                                                                                                                                                                                                                                                                                                                                                                   |
| Открытие рейтинга    | GET  | http://144.31.255.0:3001/api/likes/cats/rating          | Empty Body                                                                      | 200 | <pre>{   "dislikes": [     {       "description": "тихий, без суеты, черемша\n",       "dislikes": 40,       "gender": "unisex",       "id": 21,       "likes": 42,       "name": "Турбопетров",       "tags": ""     },     {       "description": "Изменил.",       "dislikes": 14,       "gender": "unisex",       "id": 18,       "likes": 19,       "name": "Обормотик",       "tags": ""     },     {       "description": "67",       "dislikes": 11,       "gender": "male",       "id": 20,       "likes": 11,       "name": "Вадосик",       "tags": ""     }   ], }</pre> |

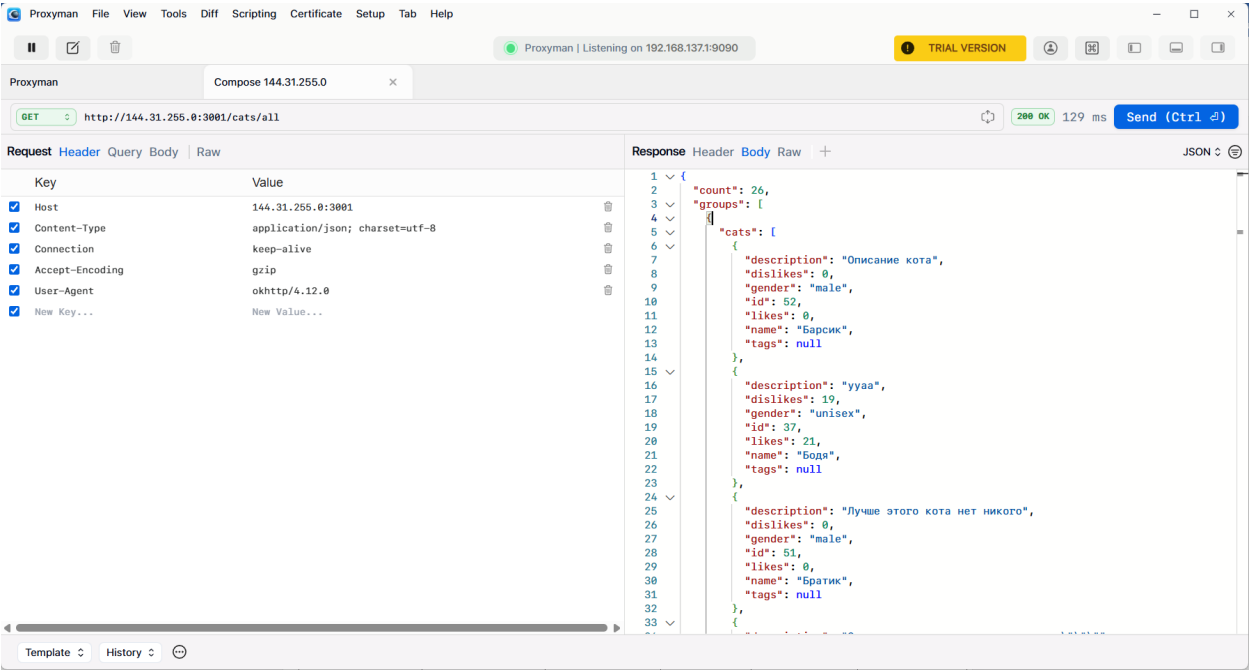
|  |  |  |  |  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|--|--|--|--|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  |  |  |  | <pre>"description": "уу", "dislikes": 6, "gender": "unisex", "id": 29, "likes": 8, "name": "Новыйбогдан", "tags": "" }, {   "description": "Запись для ручного редактирования\\\"\\", "dislikes": 4, "gender": "female", "id": 5, "likes": 4, "name": "Буся", "tags": "" }, {   "description": "Леопольд вернулся. Больше не удаляйте", "dislikes": 1, "gender": "male", "id": 30, "likes": 26, "name": "Леопольд", "tags": "" }, {   "description": "ууаа", "dislikes": 0, "gender": "unisex", "id": 37, "likes": 2, "name": "Бодя", "tags": "" }, {   "description": "Лучше этого кота нет никого", "dislikes": 0, "gender": "male", "id": 51, "likes": 0, "name": "Братик", "tags": "" }, {   "description": "великий кот новгородскийб", "dislikes": 0, "gender": "male", "id": 42, "likes": 0, "name": "Белик", "tags": "" }, {   "description": "великий кот</pre> |
|--|--|--|--|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|  |  |  |  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|--|--|--|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  |  |  | <pre>новгородский",   "dislikes": 0,   "gender": "male",   "id": 40,   "likes": 0,   "name": "Великий",   "tags": "" }, ], "likes": [   {     "description": "тихий, без суеты, черемша\n",     "dislikes": 40,     "gender": "unisex",     "id": 21,     "likes": 42,     "name": "Турбопетров",     "tags": ""   },   {     "description": "Леопольд вернулся. Больше не удаляйте",     "dislikes": 1,     "gender": "male",     "id": 30,     "likes": 26,     "name": "Леопольд",     "tags": ""   },   {     "description": "Изменил.",     "dislikes": 14,     "gender": "unisex",     "id": 18,     "likes": 19,     "name": "Обормотик",     "tags": ""   },   {     "description": "67",     "dislikes": 11,     "gender": "male",     "id": 20,     "likes": 11,     "name": "Вадосик",     "tags": ""   },   {     "description": "yy",     "dislikes": 6,     "gender": "unisex",     "id": 29,     "likes": 8,     "name": "Новыйбогдан",     "tags": ""   },   {     "description": "Запись для</pre> |
|--|--|--|--|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|  |  |  |  |  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|--|--|--|--|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  |  |  |  | <pre>ручного редактирования\"\\\"\",   "dislikes": 4,   "gender": "female",   "id": 5,   "likes": 4,   "name": "Буся",   "tags": "" }, {   "description": "Мокрые лапки, разлохмаченный животик, тыгыдямчатый, печатает на клавиатуре всякое..",   "dislikes": 0,   "gender": "unisex",   "id": 15,   "likes": 4,   "name": "Лабакот",   "tags": "" }, {   "description": "ууаа",   "dislikes": 0,   "gender": "unisex",   "id": 37,   "likes": 2,   "name": "Бодя",   "tags": "" }, {   "description": "Лучше этого кота нет никого",   "dislikes": 0,   "gender": "male",   "id": 51,   "likes": 0,   "name": "Братик",   "tags": "" }, {   "description": "великий кот новгородскийб",   "dislikes": 0,   "gender": "male",   "id": 42,   "likes": 0,   "name": "Велик",   "tags": "" } }]</pre> |
|--|--|--|--|--|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### Часть 3. Изменение запросов

#### Отправка запросов через Proxyman:



| исходный запрос                                                | изменённый<br>запрос                                           | ответ сервера                                                                                                                                                                                                                                      | изменилось<br>ли состояние<br>данных                                                            | является ли<br>поведение<br>багом или<br>security-<br>проблемой                                     | как бы вы<br>исправили<br>проблему                    |
|----------------------------------------------------------------|----------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|-------------------------------------------------------|
| http://144.31.255.0:3001/<br>api/core/cats/get-by-id?<br>id=21 | http://144.31.255.0:3001/<br>api/core/cats/get-by-id?<br>id=27 | {<br>"data": null,<br>"isBoom": true,<br>"isServer": false,<br>"output": {<br>"statusCode":<br>404,<br>"payload": {<br>"statusCode":<br>404,<br>"error": "Not<br>Found",<br>"message": "cat<br>not found"<br>},<br>"headers": {<br><br>}<br>}<br>} | Нет так как<br>это GET<br>запрос,<br>который<br>является<br>идемпотентн<br>ыми и<br>безопасными | Так как сервер<br>вернул 404 Not<br>Found и data:<br>null, он<br>корректно<br>отработал<br>ситуацию | Поскольку<br>уязвимости нет,<br>исправлять<br>нечего. |

|                                                                                                                                                                        |                                                                                                                                                                 |                                                                                                                                                                                         |                                                                                                                                                                          |                                                                                                                                                                                                   |                                                                                                               |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <code>http://144.31.255.0:3001/api/likes/cats/30/likes</code>                                                                                                          | <code>http://144.31.255.0:3001/api/likes/cats/30/likes</code>                                                                                                   | <pre>{   "description":     "Леопольд вернулся.     Больше не удаляйте",   "dislikes": 1,   "gender": "male",   "id": 30,   "likes": 30,   "name":     "Леопольд",   "tags": "" }</pre> | Да.<br>Счетчик likes был увеличен несколько раз для одного и того же пользователя и кота, хотя по логике должно быть правило "один лайк от одного пользователя на кота". | Да, это Security-проблема. Отсутствие проверки на уникальность действия позволяет злоумышленни ку накручивать счетчик лайков, что искажает рейтинги и может привести к DoS при массовой отправке. | Добавить UNIQUE constraint (ограничение уникальности) на комбинацию полей (user_id, cat_id) в таблице лайков. |
| <code>http://144.31.255.0:3001/api/core/cats/save-description</code><br><pre>{   "catDescription":     "Леопольд вернулся.     Больше удаляйте",   "catId": 30 }</pre> | <code>http://144.31.255.0:3001/api/core/cats/save-description</code><br><pre>{   "catDescription":     "Леопольд вернулся.     Удаляйте",   "catId": 30 }</pre> | <pre>{   "description":     "Леопольд вернулся.     Удаляйте",   "dislikes": 1,   "gender": "male",   "id": 30,   "likes": 30,   "name":     "Леопольд",   "tags": "" }</pre>           | Да.<br>Описание кота с id: 30 было успешно изменено на сервере.                                                                                                          | Да, это критическая Security-проблема. Сервер доверяет параметру catId из запроса и не проверяет, имеет ли текущий аутентифициро ванный пользователь права на редактирование именно этого         | Перед выполнением операции UPDATE в БД сервер должен проверить, является ли пользователь владельцем кота      |

|                                                                                                                                                                               |                                                                                                                                                                               |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                                                  | объекта.                                                                                                  |                                              |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------|-----------------------------------------------------------------------------------------------------------|----------------------------------------------|
| http://144.31.255.0:3001/api/core/cats/add<br><pre>{   "cats": [     {       "name": "Барсик",       "gender": "male",       "description": "Описание кота"     }   ] }</pre> | http://144.31.255.0:3001/api/core/cats/add<br><pre>{   "cats": [     {       "name": "Барсик",       "gender": "male",       "description": "Описание кота"     }   ] }</pre> | <pre>{   "cats": [     {       "errorDescription": "Такое значение уже существует"     }   ] }</pre>                                                                                                                                                                                                                                                                                                                                                                                                                        | Нет, так как дубликат не был создан              | Нет.<br>Это корректное и безопасное поведение.                                                            | Исправлять нечего сервер отработал правильно |
| http://144.31.255.0:3001/api/core/cats/add<br><pre>{   "cats": [     {       "name": "Барсик",       "gender": "male",       "description": "Описание кота"     }   ] }</pre> | http://144.31.255.0:3001/api/core/cats/add<br><pre>{   "cats": [     {       "name": 111,       "gender": "bruh",       "description": false     }   ] }</pre>                | <pre>{   "cats": [     {       "errorDescription": "Цифры не принимаются!"     }   ] }</pre>                                                                                                                                                                                                                                                                                                                                                                                                                                | Нет, некорректны е данные не были сохранены в БД | Нет.<br>Это корректное и безопасное поведение.                                                            | Исправлять нечего сервер отработал правильно |
| http://144.31.255.0:3001/api/core/cats/all                                                                                                                                    | http://144.31.255.0:3001/cats/all                                                                                                                                             | <pre>{ "count": 26,   "groups": [     {       "cats": [         {           "description": "Описание кота",           "dislikes": 0,           "gender": "male",           "id": 52,           "likes": 0,           "name": "Барсик",           "tags": null         },         {           "description": "ууаа",           "dislikes": 19,           "gender": "unisex",           "id": 37,           "likes": 21,           "name": "Бодя",           "tags": null         },         {           "description":</pre> | Нет, так как это GET запрос                      | Нет, сервер не отработал по первому запросу, но вернул ответ по второму, так как такой эндпоит существует | Исправлять нечего сервер отработал правильно |

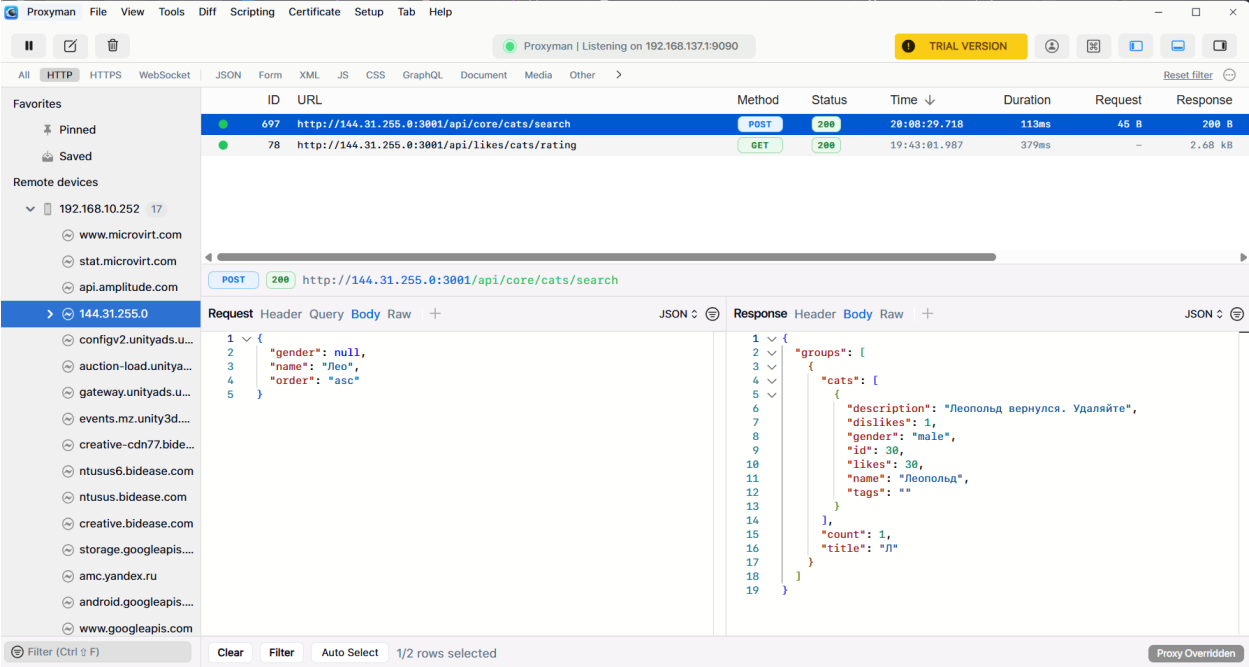
|  |  |                                                                                                                                                                                                                                                                                                                                                  |  |  |  |
|--|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|--|
|  |  | <pre>"Лучше этого кота нет никого",   "dislikes": 0,   "gender": "male",   "id": 51,   "likes": 0,   "name": "Братик",   "tags": null }, {   "description": "Запись для ручного редактирования\" \",   "dislikes": 4,   "gender": "female",   "id": 5,   "likes": 4,   "name": "Буся",   "tags": null } ], "count": 4, "title": "Б" }, ...</pre> |  |  |  |
|--|--|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|--|--|



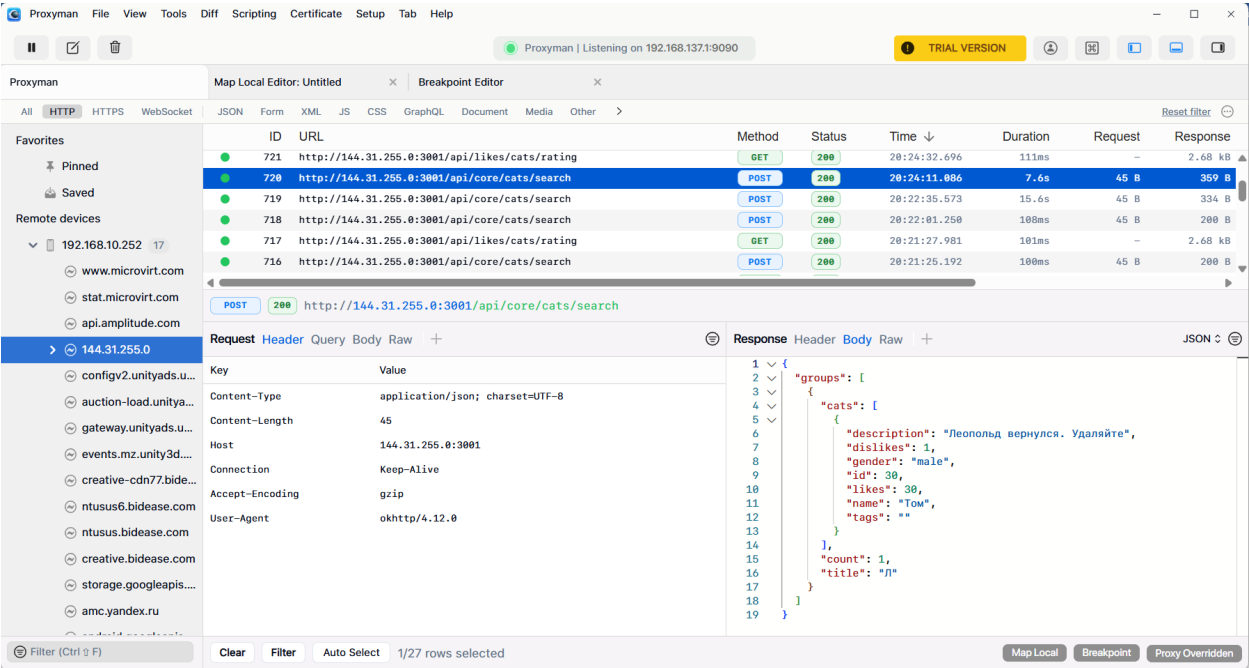
# Часть 4. Изменение ответов

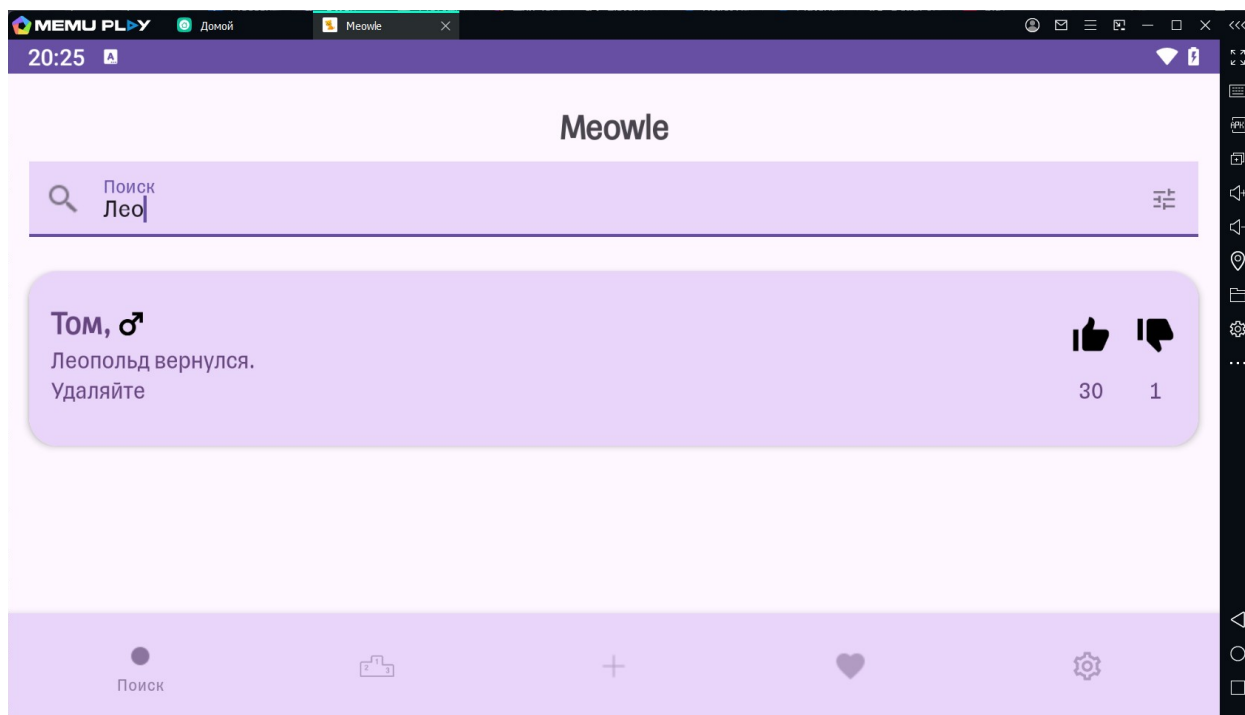
Подмените имя или описание котика в ответе поиска.

Скриншот запроса до:

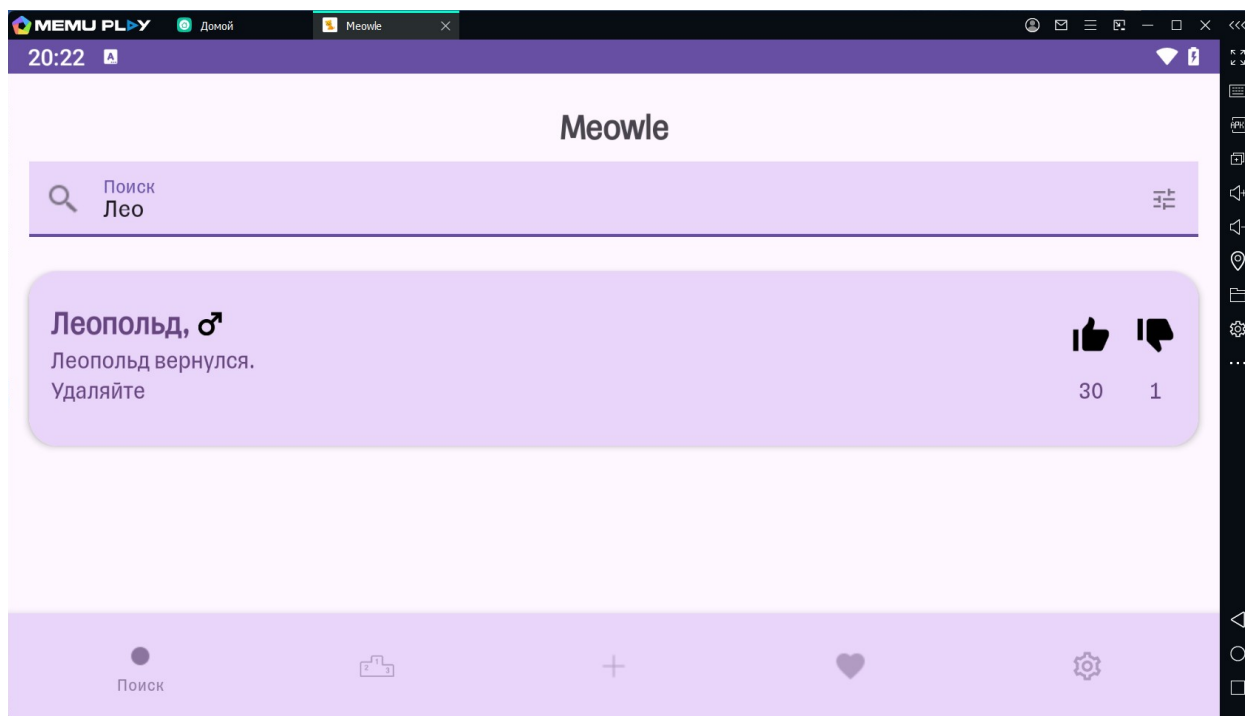


Скриншот запроса после изменения с помощью Proxyman Breakpoints:





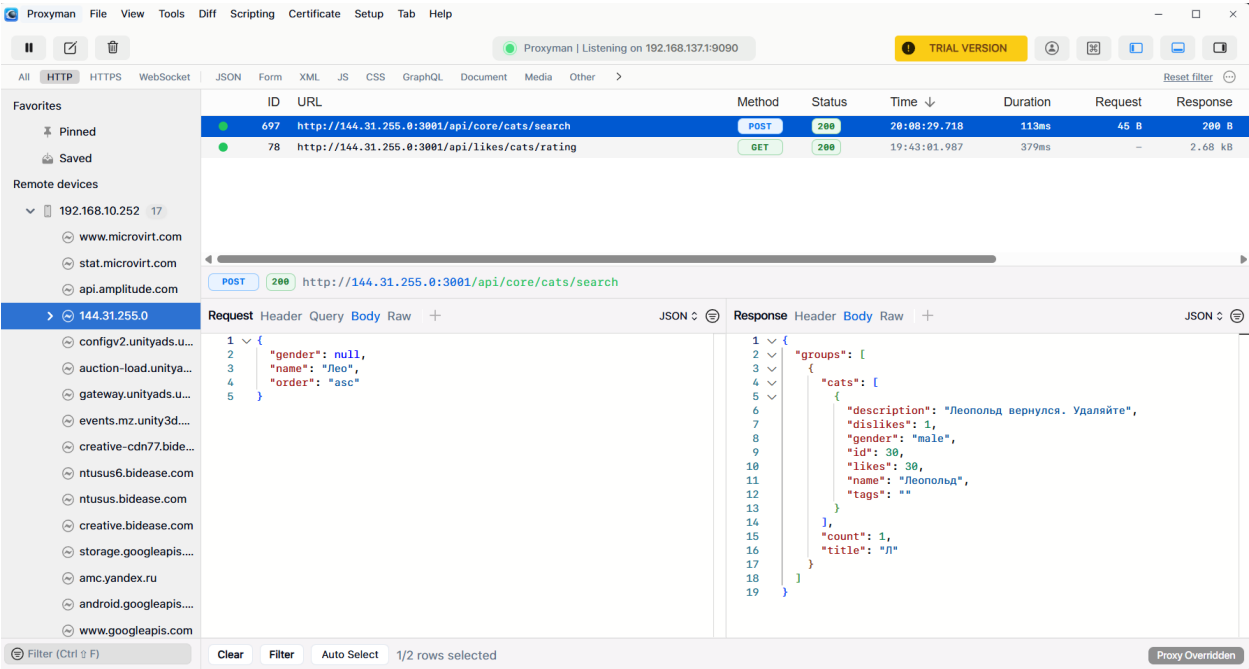
Для того что бы проверить изменилось ли что-то на стороне сервера найдём котика ещё раз:



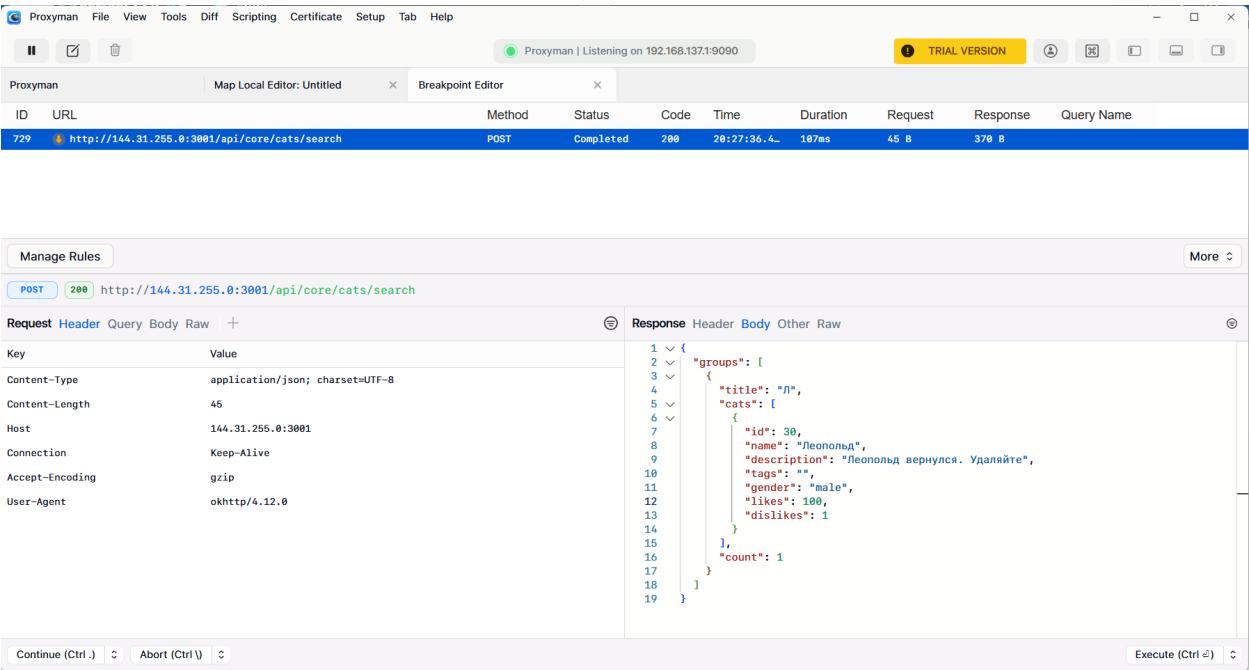
Как видно на скриншоте данные ответа никак не повлияли на то, что храниться на сервере.

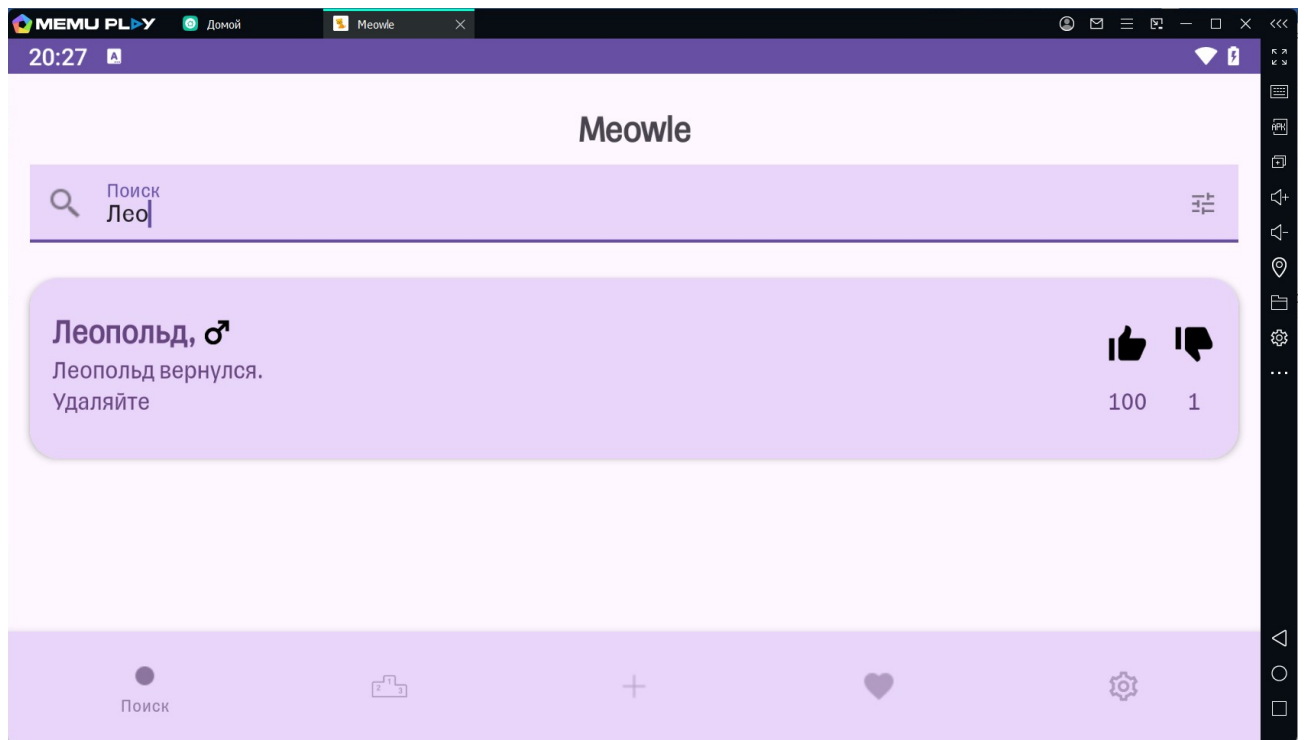
Подмените количество лайков/дизлайков.

# Скриншот запроса до:

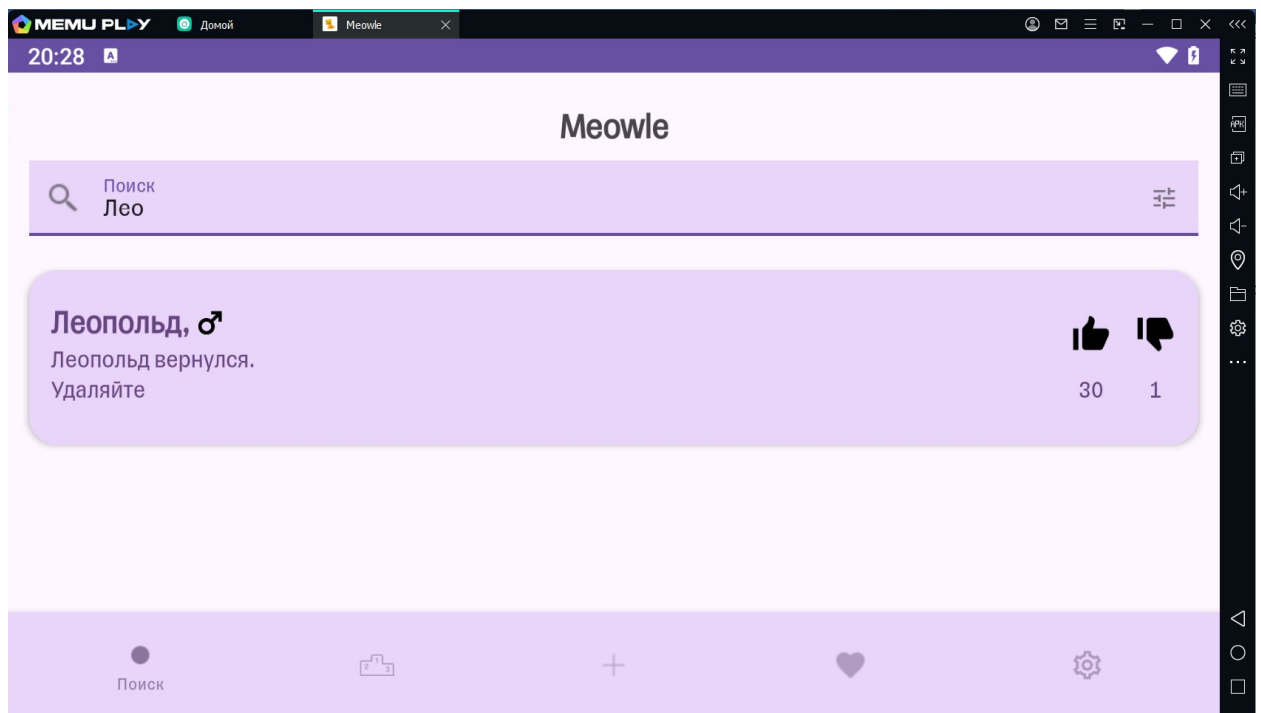


# Скриншот запроса после изменения с помощью Proxyman Breakpoints:





Для того что бы проверить изменилось ли что-то на стороне сервера найдём котика ещё раз:



Как видно на скриншоте данные ответа никак не повлияли на то, что храниться на сервере.

Подмените список результатов поиска.

Скриншот запроса до:

Proxyman | Listening on 192.168.137.1:9090

Manage Rules

POST 200 http://144.31.255.0:3001/api/core/cats/search

Request Header Query Body Raw

| Key             | Value                           |
|-----------------|---------------------------------|
| Content-Type    | application/json; charset=UTF-8 |
| Content-Length  | 45                              |
| Host            | 144.31.255.0:3001               |
| Connection      | Keep-Alive                      |
| Accept-Encoding | gzip                            |
| User-Agent      | okhttp/4.12.0                   |

Response Header Body Other Raw

```
1 {
2   "groups": [
3     {
4       "title": "л",
5       "cats": [
6         {
7           "id": 30,
8           "name": "Леопольд",
9           "description": "Леопольд вернулся. Удалайте",
10          "tags": "",
11          "gender": "male",
12          "likes": 30,
13          "dislikes": 1
14        }
15      ],
16      "count": 1
17    }
18  ]
19 }
```

Continue (Ctrl.) Abort (Ctrl.V) Execute (Ctrl.E)

Скриншот запроса после изменения с помощью Proxyman Breakpoints:

Proxyman | Listening on 192.168.137.1:9090

Manage Rules

POST 200 http://144.31.255.0:3001/api/core/cats/search

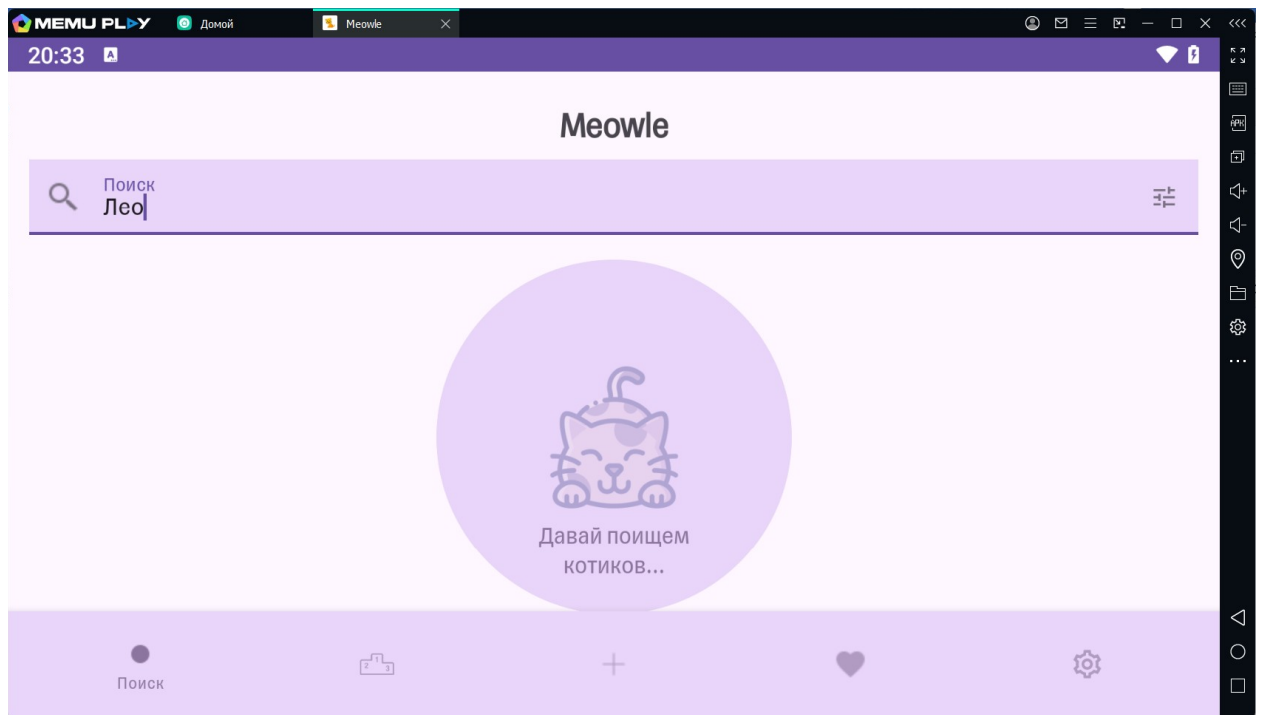
Request Header Query Body Raw

| Key             | Value                           |
|-----------------|---------------------------------|
| Content-Type    | application/json; charset=UTF-8 |
| Content-Length  | 45                              |
| Host            | 144.31.255.0:3001               |
| Connection      | Keep-Alive                      |
| Accept-Encoding | gzip                            |
| User-Agent      | okhttp/4.12.0                   |

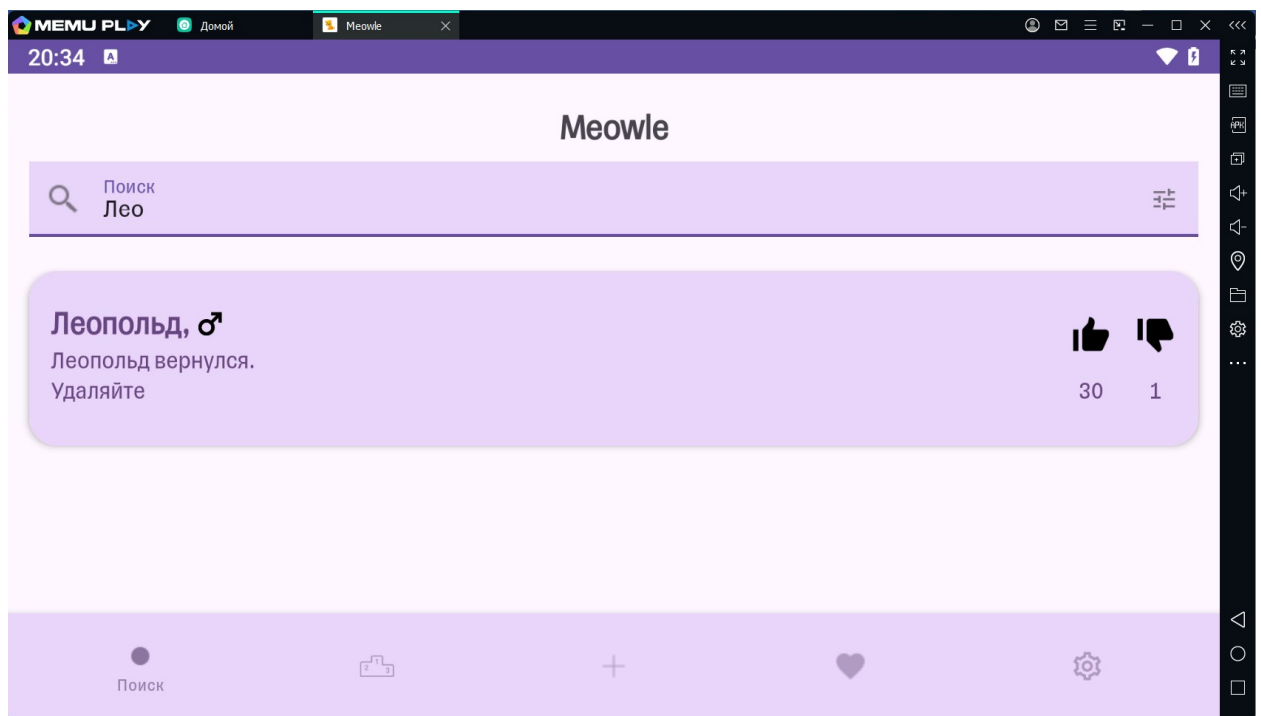
Response Header Body Other Raw

```
1 {
2   "groups": [
3     {
4       "title": "л",
5       "cats": [
6         {
7           "description": "тихий, без суеты, черемша\n",
8           "dislikes": 40,
9           "gender": "unisex",
10          "id": 21,
11          "likes": 42,
12          "name": "Турбопетров",
13          "tags": ""
14        }
15      ],
16      "count": 1
17    }
18  ]
19 }
```

Continue (Ctrl.) Abort (Ctrl.V) Execute (Ctrl.E)



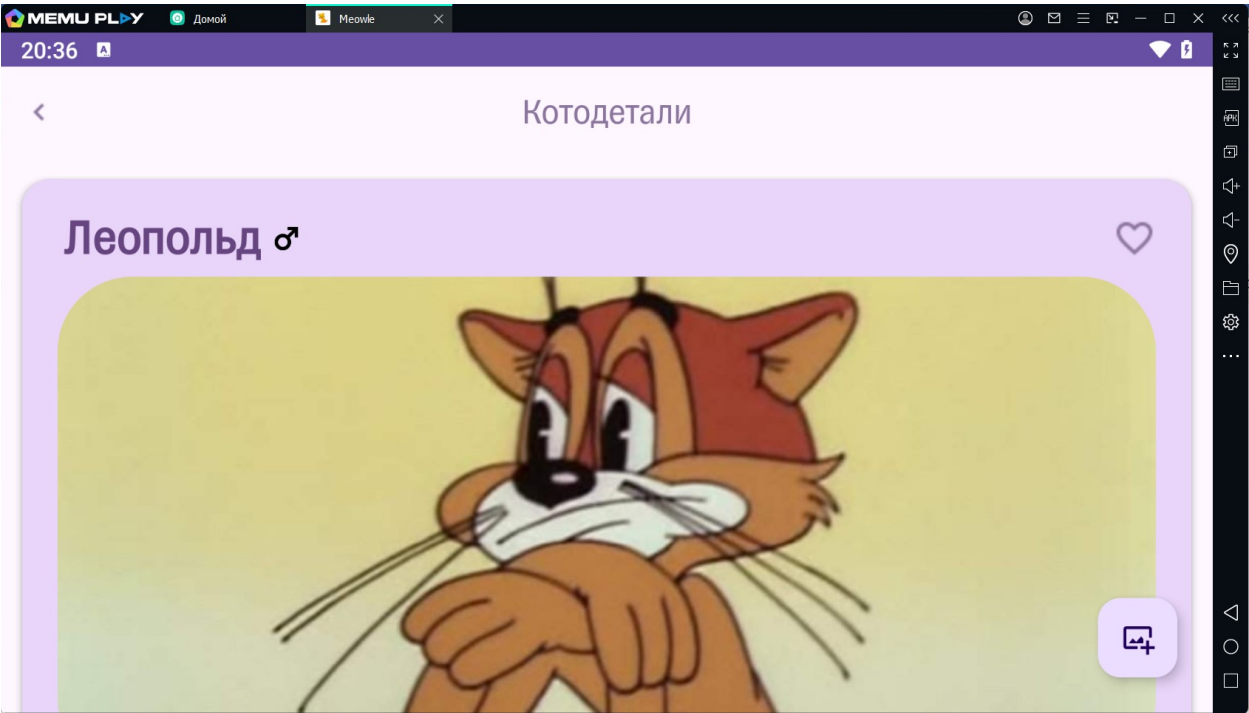
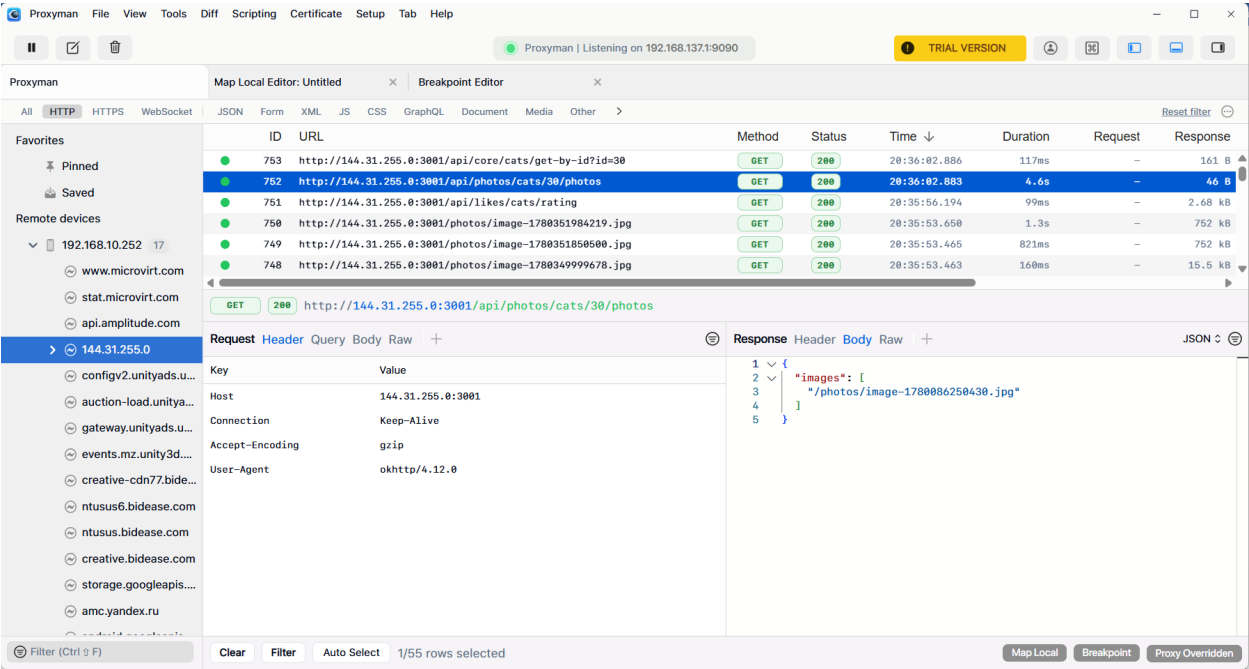
Для того что бы проверить изменилось ли что-то на стороне сервера найдём котика ещё раз:



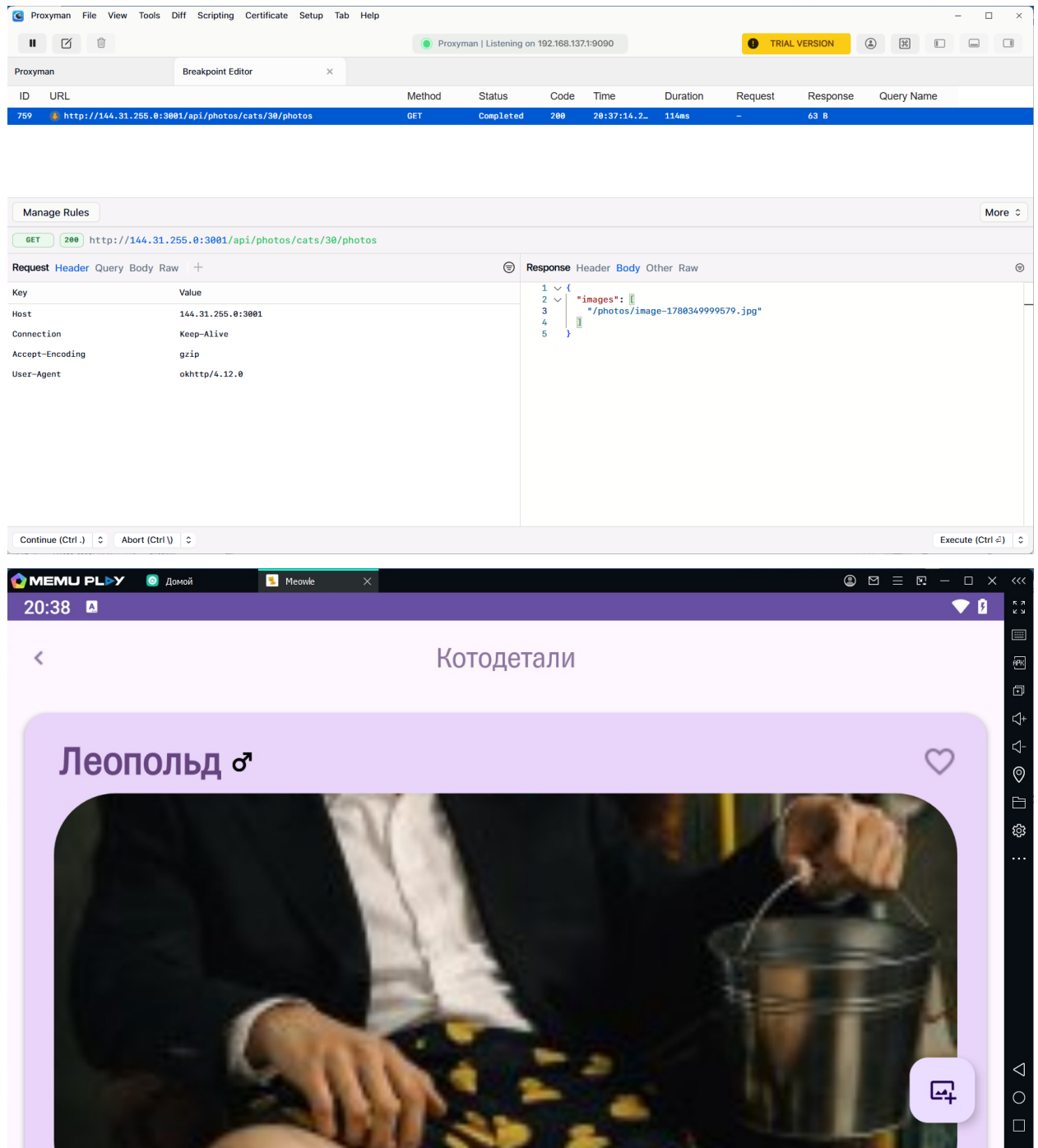
Как видно на скриншоте данные ответа никак не повлияли на то, что храниться на сервере.

Подмените список фото или URL изображения.

Скриншот запроса до:

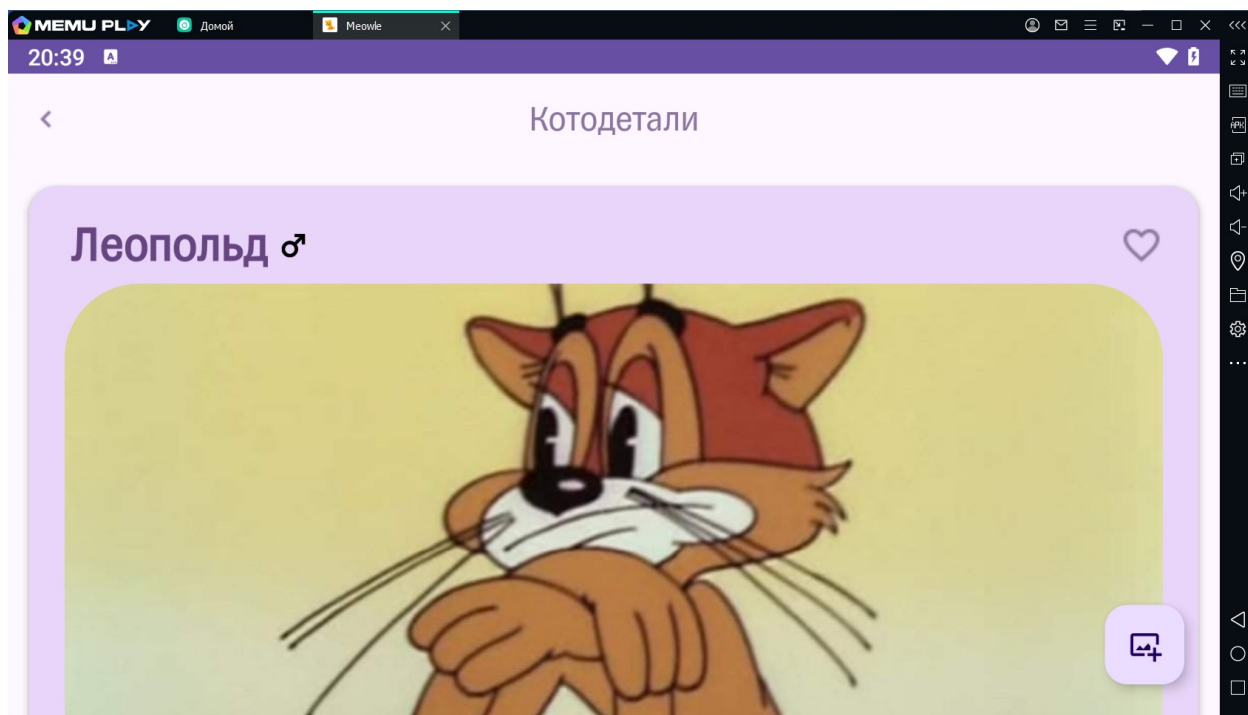


## Скриншот запроса после изменения с помощью Proxyman Breakpoints:



Для того что бы проверить изменилось ли что-то на стороне сервера откроем карточку котика ещё раз:





Как видно на скриншоте данные ответа никак не повлияли на то, что храниться на сервере.

## Часть 5. Security-анализ

### Проблема 1.

Возможность изменения чужих данных (например, описания)

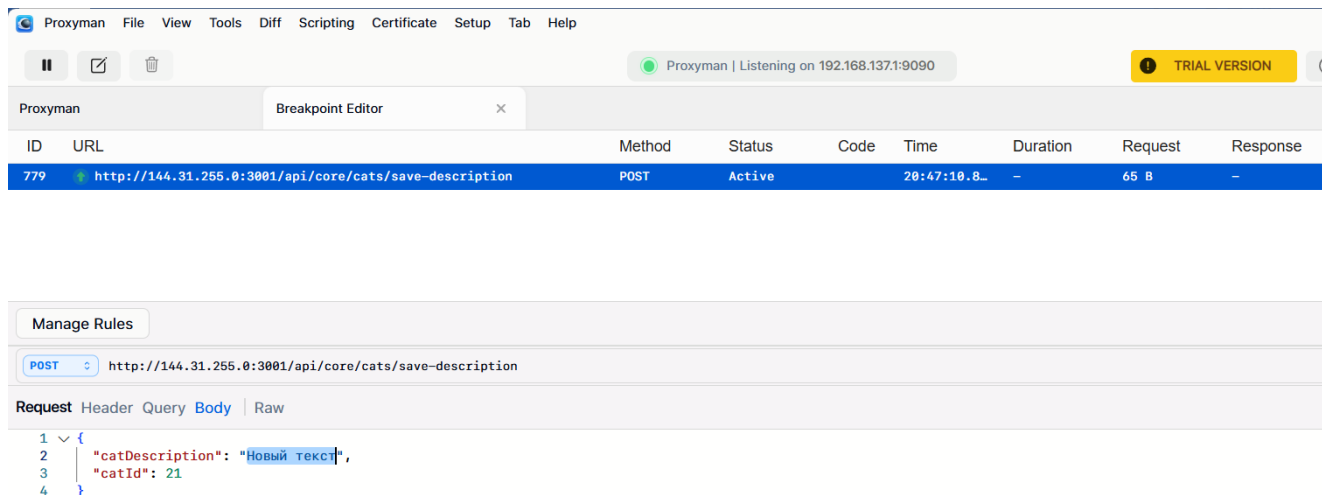
- Title: Insecure Direct Object Reference (IDOR) / Broken Object Level Authorization (BOLA) на эндпоинте изменения описания.
- Severity: Critical
- Preconditions: Знание catId любого кота в системе (например, подобранного перебором или увиденного в общем списке).
- Steps to reproduce:
  1. Перехватить запрос изменения описания в Proxyman.
  2. Изменить параметр catId в теле запроса на ID чужого кота (например, 21).
  3. Отправить запрос: POST /api/core/cats/save-description с телом {"catDescription": "Новый текст", "catId": 21}.
- Actual result: Сервер успешно обновляет описание кота и возвращает HTTP 200 с обновленными данными.
- Expected result: Сервер должен проверить права доступа и вернуть HTTP 403 Forbidden (или 404 Not Found), если пользователь не является владельцем кота.
- Evidence:
  - Request:

The screenshot shows the Proxyman application interface. At the top, there's a menu bar with options like File, View, Tools, Diff, Scripting, Certificate, Setup, Tab, and Help. Below the menu, a status bar indicates 'Proxyman | Listening on 192.168.137.1:9090'. The main window is divided into two panes. The top pane, titled 'Breakpoint Editor', shows a table of intercepted requests. The bottom pane, titled 'Request', shows the details of the selected request.

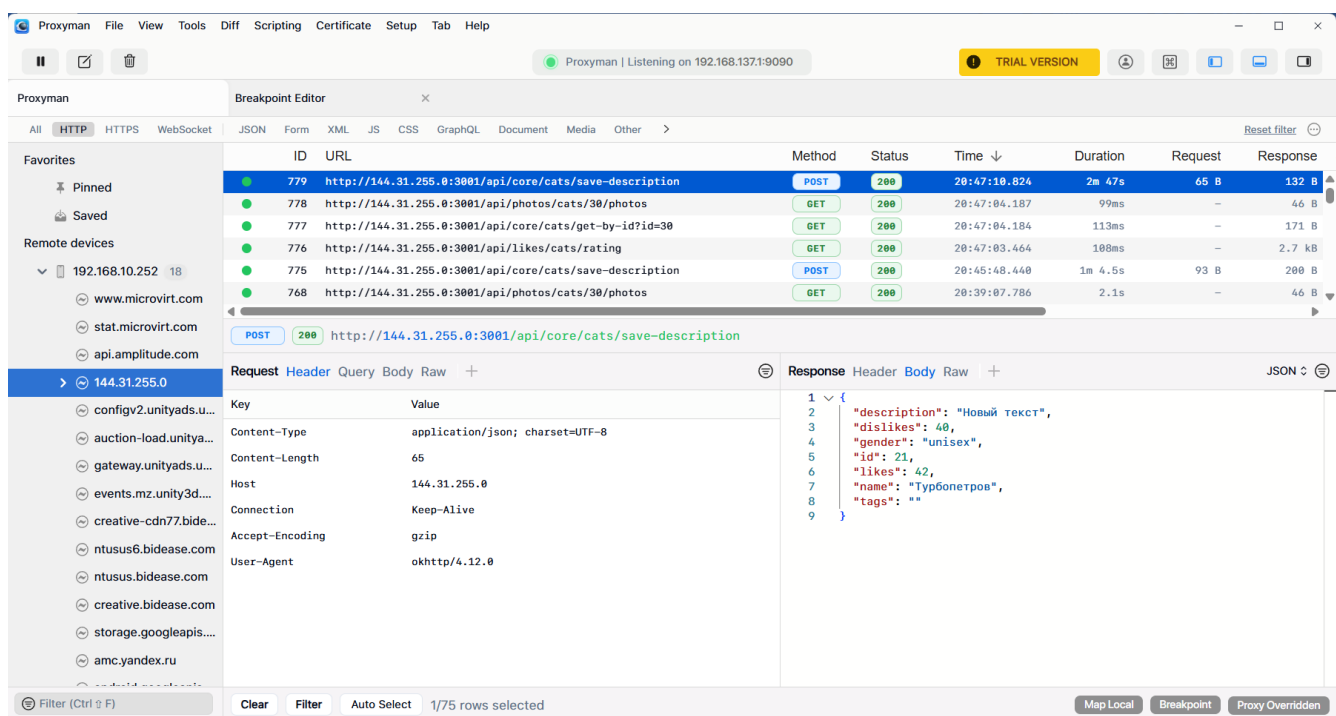
| ID  | URL                                                     | Method | Status | Code | Time          | Duration | Request | Response |
|-----|---------------------------------------------------------|--------|--------|------|---------------|----------|---------|----------|
| 779 | http://144.31.255.0:3001/api/core/cats/save-description | POST   | Active |      | 20:47:10.8... | -        | 83 B    | -        |

Below the table, the 'Request' pane shows the details of the selected request. The 'Request' tab is selected, showing the raw request body:

```
1 {
2   "catDescription": "Леопольд вернулся. Удалайте",
3   "catId": 30
4 }
```



## ○ Response:



- Recommendation: на уровне бэкенда добавить проверку: сравнивать userId из сессии/токена с ownerId объекта catId перед выполнением UPDATE.

## Проблема 2.

### Отсутствие аутентификации для критических операций

- Title: Missing Authentication: Отсутствие механизмов аутентификации при изменении данных и голосовании.
- Severity: Critical
- Preconditions: Атакующий имеет доступ к сети, где развернуто API.

- Steps to reproduce:
  1. Выполнить запросы на добавление кота, лайк/дизлайк или удаление без передачи заголовков Authorization, Cookie или JWT-токенов.
  2. Пример: `POST /api/likes/cats/30/likes` или `DELETE /api/core/cats/{catId}/remove`.
- Actual result: Сервер успешно выполняет деструктивные и модифицирующие действия, считая запрос легитимным.
- Expected result: Сервер должен требовать обязательной аутентификации и возвращать 401 Unauthorized при её отсутствии.
- Evidence: Анализ перехваченных запросов в Proxman (см. Часть 2) показывает, что заголовки авторизации отсутствуют, но операции (лайк, добавление, сохранение) проходят успешно.
- Recommendation: внедрить систему аутентификации (например, JWT). Покрыть middleware авторизации все эндпоинты, кроме публичных (поиск, получение рейтинга).

### Проблема 3.

Нарушение бизнес-логики: Многократное голосование (Накрутка рейтинга)

- Title: Business Logic Flaw: Отсутствие проверки на уникальность голоса (возможность накрутки лайков).
- Severity: High
- Preconditions: Доступ к API, наличие любого catId.
- Steps to reproduce:
  1. Отправить запрос на лайк: `POST /api/likes/cats/30/likes` с телом `{"dislike": false, "like": true}`.
  2. Повторить этот же запрос многократно (например, с помощью Proxman Repeat или скрипта).

- Actual result: Счетчик likes в базе данных увеличивается при каждом запросе (было 25, стало 26, 27 и т.д.), хотя в UI приложения кнопка лайка неактивна после первого нажатия.
- Expected result: При повторном запросе сервер должен вернуть ошибку (например, 409 Conflict или 400 Bad Request) и не изменять счетчик.
- Evidence:
  - Response 1: "likes": 26
  - Response 2 (при повторе): "likes": 27 (см. Часть 3).
- Recommendation: Добавить на уровне БД UNIQUE INDEX на поля (user\_id, cat\_id) в таблице голосов. На бэкенде обрабатывать ошибку дублирования и возвращать корректный HTTP-статус.

#### Проблема 4.

##### Отсутствие Rate Limiting (Защиты от DoS и спама)

- Title: Lack of Rate Limiting: Отсутствие ограничения частоты запросов.
- Severity: High
- Preconditions: Доступ к API.
- Steps to reproduce:
  1. Настроить автоматическую отправку сотен запросов в секунду на эндпоинты создания котиков (/api/core/cats/add) или лайков.
- Actual result: Сервер обрабатывает все запросы. Злоумышленник может заполнить базу данных мусорными записями (спам) или исчерпать ресурсы сервера (DoS).
- Expected result: При превышении разумного лимита запросов (например, более 10 в секунду с одного IP) сервер должен возвращать 429 Too Many Requests и временно блокировать клиента.
- Evidence: Успешное выполнение множественных идентичных запросов в Части 3 без каких-либо блокировок со стороны сервера.
- Recommendation: Внедрить Rate Limiting (например, с использованием Redis и библиотеки express-rate-limit или на уровне API Gateway / Nginx).

## Проблема 5.

### Некорректные HTTP-статусы при ошибках валидации

- Title: Improper HTTP Status Codes: Возврат HTTP 200 ОК при ошибках бизнес-логики и валидации.
- Severity: Medium
- Preconditions: Доступ к API.
- Steps to reproduce:
  1. Попытаться добавить кота с именем, которое уже существует.
  2. Отправить невалидные типы данных (например, число вместо строки).
- Actual result: Сервер возвращает HTTP-статус 200 ОК, а информация об ошибке передается в теле ответа в кастомном поле `errorDescription`.
- Expected result: Сервер должен использовать стандартные коды ответов: 400 Bad Request (для невалидных типов) и 409 Conflict (для дубликатов).
- Evidence:

The screenshot shows the Proxyman application interface. At the top, there's a menu bar with 'Diff', 'Scripting', 'Certificate', 'Setup', 'Tab', and 'Help'. Below it, a status bar indicates 'Proxyman | Listening on 192.168.137.1:9090' and a 'TRIAL VERSION' badge. The main area is divided into a 'Breakpoint Editor' and a list of HTTP requests. The list has columns for ID, URL, Method, Status, Time, Duration, Request, and Response. The selected request (ID 785) is a POST to 'http://144.31.255.0:3001/api/core/cats/add' with a status of 200. Below the list, the 'Request' and 'Response' tabs are visible. The 'Request' tab shows a JSON body with a cat object: `{ "cats": [ { "description": "Второй Леопольд", "gender": "male", "name": "Леопольд" } ] }`. The 'Response' tab shows a JSON body with an error message: `{ "cats": [ { "errorDescription": "Такое значение уже существует" } ] }`.

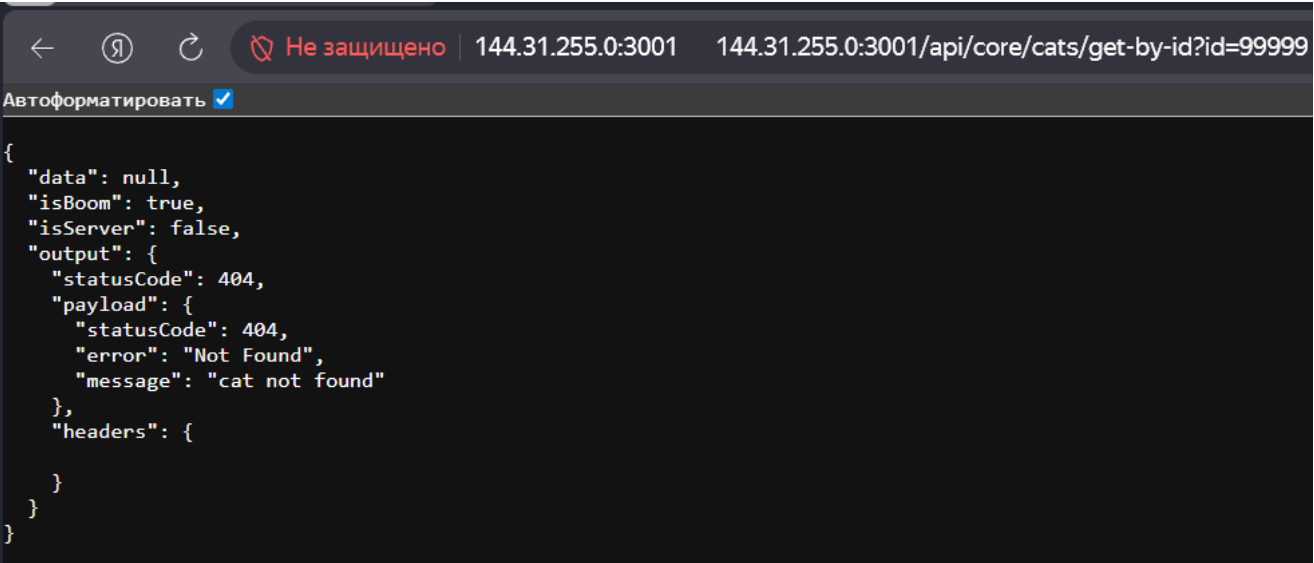
- Request: POST `/api/core/cats/add` (дубликат)
- Response: 200 OK `{"cats": [{"errorDescription": "Такое значение уже существует"}]}`

- Recommendation: Настроить глобальный обработчик исключений (Exception Filter), чтобы при ошибках валидации и бизнес-логики возвращались корректные 4xx HTTP-статусы.

## Проблема 6.

### Раскрытие информации о технологическом стеке (Information Disclosure)

- Title: Information Disclosure: Утечка данных о внутреннем устройстве и фреймворке через ответы об ошибках.
- Severity: Low
- Preconditions: Доступ к API.
- Steps to reproduce:
  1. Запросить несуществующий объект: GET /api/core/cats/get-by-id?id=99999.
- Actual result: В JSON-ответе присутствуют специфичные служебные поля, выдающие используемую библиотеку обработки ошибок.
- Expected result: Ответ должен быть минималистичным и не содержать внутренней "кухни" сервера.
- Evidence:
  - Response:



The screenshot shows a web browser window with the address bar displaying the URL `144.31.255.0:3001/api/core/cats/get-by-id?id=99999`. The page content is a JSON response indicating a 404 error. The JSON structure includes fields for `data`, `isBoom`, `isServer`, `output` (containing `statusCode`, `payload`, and `headers`), and `headers`. The `payload` field contains an `error` message and a `message` field.

```
{
  "data": null,
  "isBoom": true,
  "isServer": false,
  "output": {
    "statusCode": 404,
    "payload": {
      "statusCode": 404,
      "error": "Not Found",
      "message": "cat not found"
    },
    "headers": {
    }
  },
  "headers": {
  }
}
```

- Поля `isBoom` и `isServer` прямо указывают на использование `Node.js` фреймворка `Hapi.js` (или библиотеки `boom`), что облегчает атакующему подбор известных уязвимостей для этого стека.
- Recommendation: Скрыть внутренние поля ошибок при отдаче ответа клиенту. Оставлять только `statusCode`, `error` и `message`.

## Вывод

В ходе тестирования было наглядно доказано, что мобильному клиенту (приложению) нельзя доверять в вопросах безопасности. Клиентская часть выполняется в среде, полностью контролируемой пользователем (или злоумышленником). С помощью инструментов перехвата трафика, таких как `Proxman` или `Charles`, атакующий может:

1. Игнорировать любые ограничения пользовательского интерфейса (например, неактивные кнопки или клиентские валидации).
2. Произвольно изменять параметры запросов (подделывать `id`, типы данных, отправлять дубликаты).
3. Подменять ответы сервера, создавая иллюзию корректной работы для пользователя, даже если реальные данные на сервере не изменились.

Какие проверки должны быть реализованы строго на сервере:

1. Аутентификация и авторизация: Сервер должен проверять не только кто делает запрос (наличие валидного токена), но и имеет ли этот пользователь права на выполнение действия с конкретным объектом. Например, запрет на изменение описания чужого кота.
2. Строгая валидация входных данных: Проверка типов данных, длины строк, допустимых значений (например, `gender` должен быть только `male`, `female` или `unisex`) и санитизация данных для предотвращения XSS и инъекций.



3. Контроль бизнес-логики: Сервер должен самостоятельно отслеживать состояние. Например, перед начислением лайка проверять, не голосовал ли уже этот пользователь за данного кота, и возвращать ошибку 409 Conflict при попытке повторного действия.

4. Ограничение частоты запросов: Защита от автоматизированного спама, перебора параметров (brute-force) и DoS-атак путем блокировки IP или пользователя при превышении лимита запросов в единицу времени.

5. Принцип минимальных привилегий: API должен возвращать только те данные, которые необходимы для текущего действия, и не раскрывать внутреннюю структуру ошибок (например, убирать поля вроде isBoom из ответов).